

Month 2: Purple Team Batch 01

Scripting, Automation & Web Security

Week 7: Web Application Foundations & SQL Injection
Mastery

Instructor: **Muhammad Saad**

What is SQLi ?

Imagine a website has a **login form** where you enter your **username and password**. Behind the scenes, the website checks the database using a command written in **SQL**.

Normally the website asks the database something like:

“Check if this username and password exist.”

But in **SQL Injection (SQLi)**, a hacker **types special database commands into the input box** instead of normal text.

The hacker tricks the website into running **their own database commands**. This can allow them to:

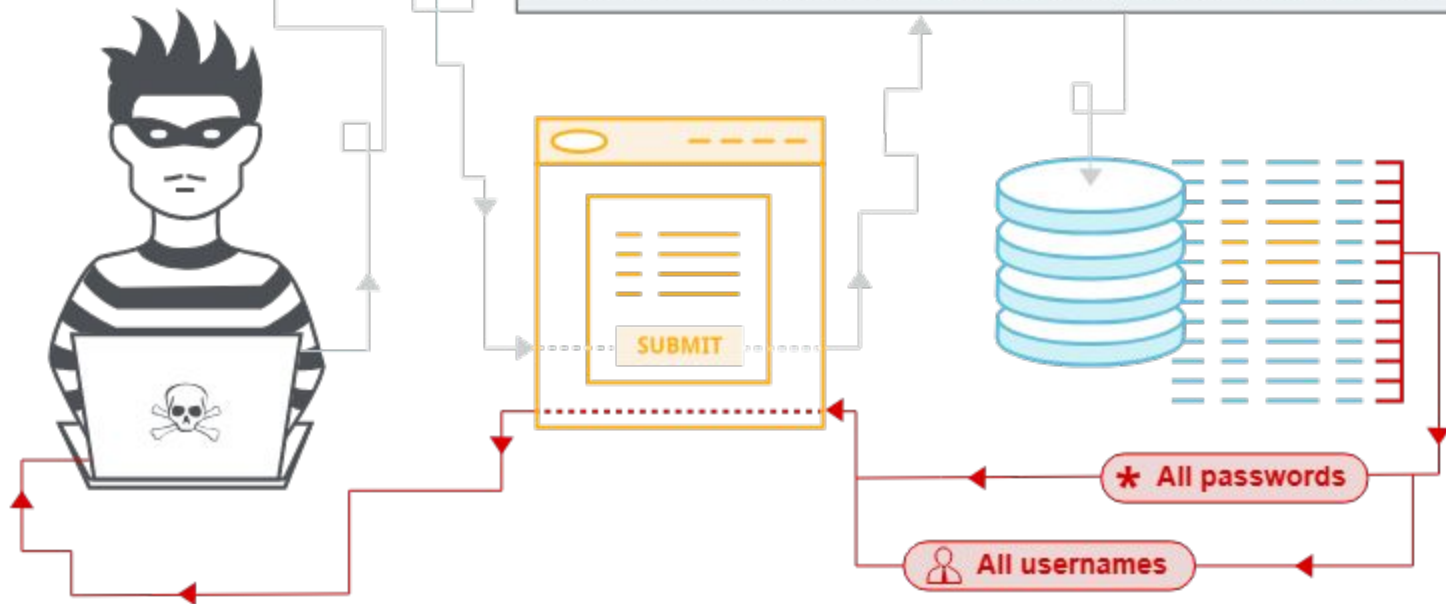
- Log in **without a password**
- **See private data** (users, emails, passwords)
- **Change or delete data**
- Sometimes **take control of the whole database**

Easy Example

Instead of typing a normal username, a hacker types something like: ' OR '1'='1

```
' UNION SELECT username, password FROM users--
```

```
SELECT name, description FROM products WHERE category  
= 'Gifts' UNION SELECT username, password FROM users--
```



What is In-Band SQLi ?

In this attack, the **hacker sends the SQL injection and receives the results through the same communication channel** (the same webpage response).

Error-Based SQL Injection

Error-based SQLi uses **database error messages** to get information.

If the website shows **database errors**, the attacker can purposely cause errors and read useful data from them.

Example concept:

Input: ' OR 1=1 --

The attacker can learn:

- Database structure
- Table names
- Column names
- Sometimes actual data

Union-Based SQLi

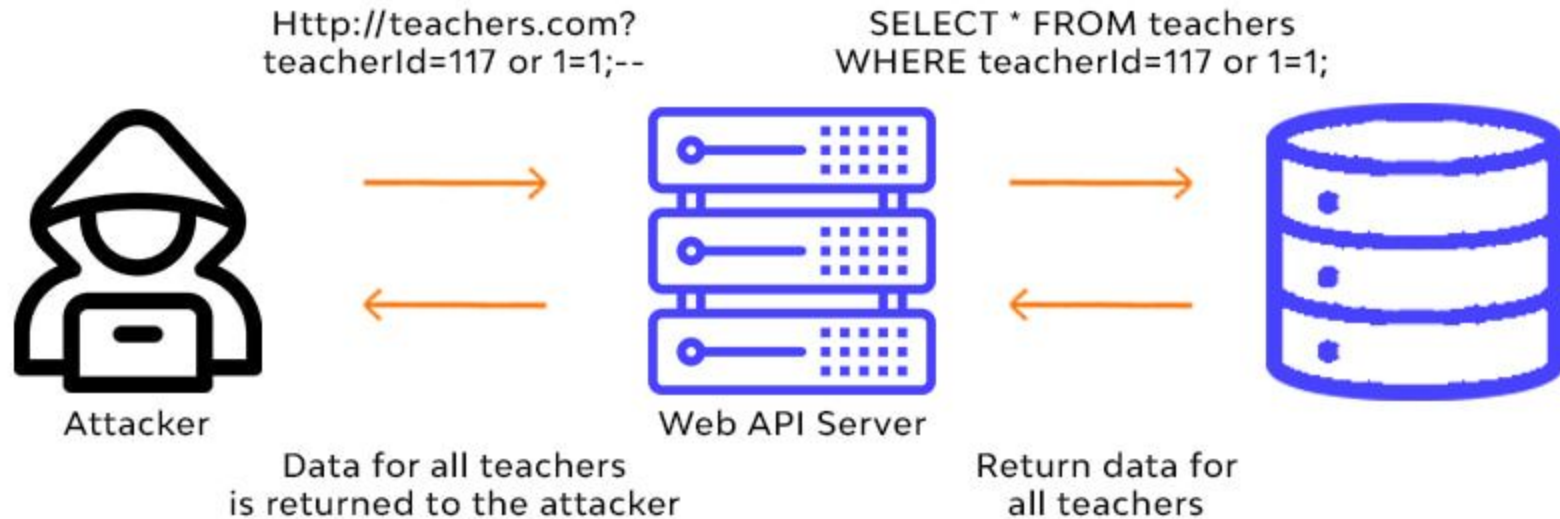
Union-based SQL injection uses the SQL **UNION** operator to combine results from multiple queries.

Example idea:

```
SELECT name FROM products
UNION
SELECT username FROM users
```

The **UNION** operator merges results from another table and shows them on the page.

SQL Injection



What is Blind SQLi ?

Blind SQL Injection happens when a website is **vulnerable to SQL injection but does not show database errors or data directly**. So the attacker **cannot see the database results**, but they can still **figure out the data by observing the website's behavior** (like page changes or response time).

The hacker asks the database **true/false questions** and watches how the website responds.

Example logic: Is the first letter of the database name = 'a' ?

If **true** → page behaves normally & If **false** → page behaves differently

Boolean-Based SQLi

This type uses **TRUE or FALSE conditions** where the attacker injects a condition and watches **how the webpage changes**.

Normal query: `SELECT * FROM users WHERE id = 1`

Injected query idea: `1 AND 1=1`

Result:

- If **TRUE** → normal page appears
- If **FALSE** (`1 AND 1=2`) → page changes (empty page or error)

Time-Based SQL Injection

Error-based SQLi uses **database error messages** to get information.

If the website shows **database errors**, the attacker can purposely cause errors and read useful data from them.

Example concept:

Input: `' OR 1=1 --`

Best of Luck for the Week 7 Tasks

Instructor: **Muhammad Saad**